

Narrativa explicativa de la encuesta

1. Por qué esta encuesta y por qué ahora

Las vulnerabilidades han pasado de ser una preocupación puramente técnica a convertirse en un asunto estratégico. En un mundo en el que unas pocas **vulnerabilidades explotadas conocidas (KEV)** explican buena parte de los incidentes graves, ya no es suficiente con «tener un buen antivirus» o «pasar un escáner de vez en cuando».

Esta encuesta nace con una vocación sencilla y ambiciosa a la vez:

- Ayudar a cada organización a entender dónde está realmente en materia de gestión de vulnerabilidades, pentesting, monitorización y formación.
- Proporcionar una base cuantitativa para priorizar inversiones y decisiones.
- Servir como lenguaje común entre técnica, negocio y dirección.

No pretende ser un examen ni una auditoría encubierta. Es, más bien, un espejo cuidadosamente pulido: cuanto más honestamente se responda, más útil será la imagen que devuelva.

2. Qué mide exactamente la encuesta

La encuesta explora la madurez de la organización en seis grandes bloques:

1.
Gobierno y estrategia de vulnerabilidades (GOV)
Si existen políticas claras, responsabilidades definidas y una integración real con la gestión de riesgos.
2.
Gestión operativa de vulnerabilidades y KEV (VUL)
Cómo se inventarian los activos, se detectan y priorizan las vulnerabilidades (en especial las KEV), y se controla el tiempo de remediación.
3.
Pruebas de penetración y ejercicios (PEN)
Con qué frecuencia se realizan, qué alcance tienen, y cómo se aprovechan sus resultados.
4.
Monitorización, SIEM y detección (SIEM)
La capacidad de ver y entender qué ocurre en la red y los sistemas, en particular frente a la explotación de vulnerabilidades.
5.
Capacitación y cultura de seguridad (AWR)
La preparación de las personas, tanto en buenas prácticas generales como en aspectos técnicos especializados.
6.
Métricas, indicadores y ROI (MET)
Qué se mide, cómo se reporta y cómo se conectan los esfuerzos de seguridad con el lenguaje del negocio.

Gobierno y estrategia de vulnerabilidades (GOV)

Si existen políticas claras, responsabilidades definidas y una integración real con la gestión de riesgos.

Gestión operativa de vulnerabilidades y KEV (VUL)

Cómo se inventarian los activos, se detectan y priorizan las vulnerabilidades (en especial las KEV), y se controla el tiempo de remediación.

Pruebas de penetración y ejercicios (PEN)

Con qué frecuencia se realizan, qué alcance tienen, y cómo se aprovechan sus resultados.

Monitorización, SIEM y detección (SIEM)

La capacidad de ver y entender qué ocurre en la red y los sistemas, en particular frente a la explotación de vulnerabilidades.

Capacitación y cultura de seguridad (AWR)

La preparación de las personas, tanto en buenas prácticas generales como en aspectos técnicos especializados.

Métricas, indicadores y ROI (MET)

Qué se mide, cómo se reporta y cómo se conectan los esfuerzos de seguridad con el lenguaje del negocio.

Cada pregunta del cuestionario está diseñada para tocar una pieza específica de este puzle. Juntas, componen un mapa razonablemente detallado del estado de la casa.

3. Filosofía de diseño: riguroso, pero sin dramatismos

El diseño de la encuesta se apoya en buenas prácticas internacionales (CISA KEV, NIST, ISO, ENS, NIS2...) y en la experiencia acumulada en proyectos similares. Ahora bien, se ha cuidado especialmente que:

- El lenguaje sea claro, evitando tecnicismos innecesarios.
- Las opciones de respuesta sean realistas, reconociendo que la perfección absoluta rara vez se encuentra fuera de los folletos comerciales.
- Se pueda contestar con honestidad sin miedo al linchamiento: la idea es conocer la realidad, no maquillarla.

Por eso, muchas preguntas ofrecen opciones que, aunque algo irónicas, reflejan situaciones muy habituales. Si al leer una opción piensa «nos han visto», es probable que sea la respuesta correcta.

4. Cómo interpretar los resultados

4.1 Índice Global de Madurez (IGM)

Del análisis de las respuestas se deriva un **Índice Global de Madurez (IGM)**, expresado en una escala numérica (por ejemplo, de 0 a 100) y traducido a niveles cualitativos:

- Nivel 1 – Inicial: prácticas ad hoc, alta dependencia de personas clave, poca estandarización.
- Nivel 2 – Básico: existen políticas y procesos, pero su aplicación es desigual.
- Nivel 3 – Definido: procesos documentados y aplicados de forma consistente, aunque mejorables.
- Nivel 4 – Gestionado: medición sistemática, mejora continua, buen alineamiento con el negocio.
- Nivel 5 – Optimizado: enfoque proactivo y adaptativo, uso intensivo de automatización y analítica.

Habitualmente, las organizaciones se sitúan en un rango intermedio, con fortalezas en algunos bloques y debilidades en otros. Eso es precisamente lo interesante: detectar **asimetrías**.

4.2 Subíndices por dimensión

Además del IGM global, se calculan subíndices por cada bloque (GOV, VUL, PEN, SIEM, AWR, MET). Estos subíndices permiten:

- Comparar el nivel relativo entre dimensiones (por ejemplo, «somos fuertes en formación, débiles en vulnerabilidades»).
- Identificar puntos de palanca donde una mejora acotada puede tener un impacto significativo.

La idea no es etiquetar áreas como «aprobadas» o «suspensas», sino establecer un **orden de prioridades razonado**.

5. De los datos a las decisiones

Una vez calculados los índices y analizados los resultados, el valor real viene de **lo que se hace después**:

- Traducir debilidades en iniciativas concretas (por ejemplo, «implantar un proceso formal de gestión de KEV con SLAs claros»).
- Estimar para cada iniciativa su impacto esperado (reducción de riesgo, mejora de cumplimiento, aumento de resiliencia) y su coste aproximado.
- Evaluar el ROI de las inversiones propuestas, no solo en términos financieros, sino también regulatorios, reputacionales y operativos.

La plantilla Excel propuesta ayuda a esa cuantificación, pero las decisiones finales siempre tendrán un componente de criterio y contexto: ningún modelo sustituye al juicio experto.

6. Qué NO hace esta encuesta (y conviene recordar)

Para evitar malentendidos, es importante subrayar qué no pretende hacer este instrumento:

- No es una auditoría de cumplimiento: aunque mapea a normas y estándares, no sustituye a auditorías formales.
- No es un pentest ni un escáner de vulnerabilidades: habla de procesos, capacidades y cultura, no de CVE concretas abiertas en sus sistemas.
- No ofrece una «nota final» definitiva: el IGM es una herramienta de trabajo, no un veredicto inapelable.

Dicho de otro modo: si la encuesta revela áreas verdes en madurez, fantástico; si además sus pentests y logs del SIEM cuentan la misma historia, mejor aún. Si no la cuentan, habrá que investigar quién miente.

7. Cómo sacar el máximo partido a la encuesta

Algunas recomendaciones prácticas:

7.
Involucrar a los perfiles adecuados
Asegúrese de que responden quienes conocen de primera mano los temas preguntados (CISO, responsables de TI, responsables de formación, responsables de continuidad, etc.).
8.
Fomentar respuestas honestas
Explique que el objetivo es mejorar, no buscar culpables. Idealmente, garantice anonimato a nivel individual y enfoque los resultados a nivel agregado.
9.
Compartir una síntesis de resultados
Devuelva a quienes han participado una visión general de las conclusiones, para reforzar la sensación de que su tiempo ha merecido la pena.
10.
Combinar con otras evidencias
Confronte las percepciones con datos: resultados de pentests, indicadores del SIEM, informes de auditoría, incidentes recientes.
11.
Repetir en el tiempo
Repetir la encuesta cada 12–24 meses permite medir la evolución y comprobar si las iniciativas implantadas están dando frutos.

Involucrar a los perfiles adecuados

Asegúrese de que responden quienes conocen de primera mano los temas preguntados (CISO, responsables de TI, responsables de formación, responsables de continuidad, etc.).

Fomentar respuestas honestas

Explique que el objetivo es mejorar, no buscar culpables. Idealmente, garantice anonimato a nivel individual y enfoque los resultados a nivel agregado.

Compartir una síntesis de resultados

Devuelva a quienes han participado una visión general de las conclusiones, para reforzar la sensación de que su tiempo ha merecido la pena.

Combinar con otras evidencias

Confronte las percepciones con datos: resultados de pentests, indicadores del SIEM, informes de auditoría, incidentes recientes.

Repetir en el tiempo

Repetir la encuesta cada 12–24 meses permite medir la evolución y comprobar si las iniciativas implantadas están dando frutos.

8. Tono y cultura: tomarse en serio la seguridad, no a uno mismo

La ciberseguridad es un asunto serio, pero eso no obliga a que todas las conversaciones sobre ella sean grises y solemnes. Un cierto tono irónico y cercano puede ayudar a:

- Romper barreras defensivas («no somos los únicos con problemas»).
- Facilitar respuestas más sinceras.
- Recordar que mejorar es un proceso, no una humillación pública.

Por eso encontrará en el cuestionario opciones de respuesta que describen con humor situaciones muy reales. La idea no es reírse de nadie, sino **reconocer la realidad tal y como es**, para poder transformarla en lo que debería ser.

9. Cierre

Esta encuesta no es una varita mágica ni un oráculo. Es una herramienta de trabajo: si se usa con honestidad, rigor y espíritu constructivo, puede convertirse en un excelente punto de partida para conversaciones importantes sobre riesgo, resiliencia y prioridades.

El resto depende de ustedes: de su disposición a mirar el espejo, comentar lo que ven y ponerse manos a la obra. La buena noticia es que, en materia de ciberseguridad, cada paso sensato que se da reduce la probabilidad de que la próxima vulnerabilidad explotada famosa lleve el nombre de su organización en la nota de prensa.